

M5cet 6.12 — bezpečnostní analýza a srovnání (shrnutí)

Stav kódu: verze 6.12.0, commit 2ec130fa (master) · analýza ke dni 2026-10-05 · revize zdrojového kódu (server, web, Android) pěti nezávislými průchody s doložením soubor:řádek · údaje o konkurenci z veřejných zdrojů k 10/2026 · podrobně docs/security-analysis.md, docs/protocol-v4.md, docs/review-612.md; zdroje: docs/security-summary-6.12-zdroje.md

Verdikt: $\approx 5,5$ / 10 vůči Signalu (10 = Signal v dané oblasti; kap. 13 analýzy uváděla 6,5 — tato revize je přísnější, viz níže).

- Kryptografický protokol pro zprávy je silný:** hybridní post-quantové ustavení klíče, Double Ratchet s post-quantovým ratchetem, průhlednost klíčů — na papíře úroveň Signalu a před Threemou, WhatsAppem a Telegramem.
- Celkovou bezpečností nepředčí Signal ani Threemu:** kód webu doručuje server, hovory nejsou plně E2EE (Android, starší prohlížeče), server zná a ukládá hodně metadat, kořenem důvěry místnosti je sdílené heslo a nic nebylo nezávisle auditováno.
- Unikátní:** bez telefonního čísla, jen na vlastním serveru, bohaté serverové moduly (funkce, AI, telefonie, NFC) — za cenu velké plochy útoku, kde server pracuje s čitelnými daty.

1. Co je v kódu dobře (ověřeno)

Oblast	Implementace (web client/src/lib/p4, Android cz.m5cet.app.p4)
Ustavení klíče	Hello v4: efemérní ECDH P-256 + ML-KEM-768 (noble 0.7.1 / Bouncy Castle 1.86), obě strany zapouzdří, kořen = HKDF přes přepis podepsaný klíčem zařízení — bezpečné, pokud vydrží P-256 nebo ML-KEM.
Ratchet	Double Ratchet; každý krok DH přimíchá nový klíč ML-KEM (ověřeno, že běží i na Androidu). FS + PCS + PQ pro dvojice; stav se mění až po AEAD; sezení jen v paměti, každé připojení = nový handshake.
Skupiny	Sender keys s vlastním podpisovým klíčem řetězu (držitel řetězu nemůže psát za odesílatele), certifikát vázaný na vlastníka, rotace po 100 zprávách / 15 min a při odchodu člena. Obsah není podepsán dlouhodobým klíčem (popiratelnost).
Nepřítomní, soubory	Schránky pro každé ověřené zařízení (ECDH + ML-KEM, FS omezená ≈ 38 dní), náhodný klíč pro každý soubor, padding do tříd, trvalé okno proti přehrání (31 dní), ochrana proti downgrade.
Identita	Stavy nový / ověřený / změněný (zadržení zpráv), bezpečnostní čísla a QR, certifikáty zařízení v2 (90 dní, odvolání), log průhlednosti klíčů (RFC 9162) s gossipem a sledováním vlastních zařízení.
Android	Zámek zahodí datový klíč (zprávy do zapečetěné schránky zámku), PIN přes Keystore StrongBox/TEE, čítač odolný návratu zálohy, nouzový PIN, FLAG_SECURE, zálohy vypnuté, design bez JavaScriptu s podepsanými balíčky, ověřená aktualizace APK.
Server	SQLCipher pro functions.db, telephony.db a uživatelské DB; sandbox funkcí v bubblewrap (je-li nainstalován), přísná CSP bez unsafe-inline, ověřování podpisů webhooků, auditní řetěz s podpisy, check.sh.

2. Hlavní slabiny (aktuální kód)

Váha	Nález	Kde / důsledek
Vysoká	Web doručuje server (F-02): kontrola podepsaného vydání je ve výchozím nasazení nečinná — instalátor i Docker staví web na hostiteli, manifest je nepodepsaný, klíč nepřipnutý; kontrolu navíc provádí sám kontrolovaný kód.	integrity.ts, script/build.ts — zlý provozovatel podvrhne klienta.
Vysoká	Hovory: otisky DTLS chrání jen klíč místnosti a nejsou vázané na identitu; E2EE rámců jen na webu s RTCTpScriptTransform, Android ji nemá (jen DTLS-SRTP).	envelope.ts, Calls.java — kdo zná heslo a ovládá hub, odposlechne hovor.
Střední	Sdílené heslo jako kořen důvěry: náhodný klíč je jen nabídnutý, slabý klíč projde po potvrzení, přidání místnosti (více místnosti) a Android sílu nekontrolují; slepé ID i ověřovací klíč hubu jsou offline orákulum hesla.	RoomDialog.tsx, App.tsx, proof.ts
Střední	Metadata na serveru: slepá ID místností nešifrované v m5cet.db (fronta relay, „prýč“), účty a e-maily upozornění v JSON, hash místností v hlavičkách push (FCM collapse key, Web Push Topic), čísla a těla příchozích SMS v telephony-events.json, polohy telefonů v android.db; master klíč leží ve výchozím stavu vedle databáze; peří vidí své IP (ICE „all“, záloha Google STUN).	nešifrované: m5cet.db, ai/journal.db, android.db, soubory JSON
Střední	Důkaz členství na hubu není ve výchozím stavu vynucen (HUB_REQUIRE_ROOM_PROOF): kdo zná slepé ID, vidí seznam členů, jména a přítomnost.	proof.ts, hub.ts
Střední	Cesty pod klíčem místnosti (bez FS, podepsané klíčem zařízení): neznámý peer po 2,5 s, klienti protokolu 3, nikdy neověřené účty v relay; signalizace SDP/ICE.	App.tsx, p4-away.ts
Střední	Sandbox funkcí: instalátor ani Docker neinstalují bubblewrap → výchozí je jen permission model Node (síť blokuje stuby v JS); bez seccomp.	isolation.ts, Dockerfile
Střední	Konzole: dlouhodobé bearer tokeny bez 2FA a minimální délky, blokování jen podle IP; CSP connect-src ws: wss: na libovolný host.	admin-users.ts, server/index.ts
Střední	Ověřitelnost: žádný nezávislý audit ani formální model; ML-KEM knihovna pre-1.0 bez auditu, chybí známé vektory FIPS 203; testovací vektory generuje sám web; Android testy nejsou v CI; build není reprodukovatelný.	test/vectors/p4.json, .github/workflows
Nízká	Web dál přijímá přenosy souborů v1 (PBKDF2, bez AAD); hello protokolu 3 podepisuje čitelný název místnosti; značky downgrade a piny v localStorage; zámek Androidu měří čekání časem zařízení; bez TLS pinningu na Androidu; KCI u schránky; log klíčů vede tentýž provozovatel (bez svědků, hash uživatele bez soli).	více míst

Kde dokumentace 6.12 přečeňuje: „výchozí náhodný klíč místnosti“ (jen nabídka), „klíč médií pro každý hovor“ (jen web), výčet nešifrovaných úložišť a metadat (neúplný), kontrola podepsaného vydání (ve výchozím nasazení neběží), hodnocení 6,5 → zde 5,5.

3. Srovnání bezpečnosti a protokolu (k 10/2026)

	M5cet 6.12	Signal	WhatsApp	Threema	Telegram	iMessage
E2EE výchozí	chat, soubory, schránky; hovory jen web + DTLS; mimo E2EE : funkce, AI, řeč, telefonie	vše vč. záloh (klíč obnovy)	chaty a hovory; mimo: firemní Cloud API, Meta AI, zálohy jen volitelně	vše (zálohy Safe bez chatů)	ne — cloudové chaty a skupiny čte server; tajné chaty jen 1:1	iMessage ano; iCloud bez ADP klíč u Applu; RCS E2EE beta
FS / PCS 1:1	ano / ano (Double Ratchet + KEM)	ano / ano (Triple Ratchet)	ano / ano (Signal Protocol)	FS (lbex; s multi-device ne) / PCS neuvedeno	tajné chaty: FS (rekey) / ne	ano / ano (PQ3)
Post-kvantová	ano — ustavení i ratchet (ML-KEM-768)	ano — PQXDH + SPQR (zavádí se)	nedokumentováno	plán s IBM, nenasazeno	neohlášeno	ano — PQ3
Skupiny	sender keys v4, rotace 100 zpráv / 15 min; heslo místnosti	sender keys, privátní skupiny (server nezná členy)	sender keys	párově každému členovi	bez E2EE (jen hovory)	fan-out na zařízení
Ověření / KT	čísla + QR, stavy identity; vlastní KT log (provozovatel, bez svědků)	čísla + QR; automatické ověření přes KT (2026)	čísla + QR; KT (AKD, audit Cloudflare)	3 úrovně, QR; bez KT	emoji v tajných chatech	Contact Key Verification (KT, volitelně)
Tel. číslo	ne (passkey účet)	zatím ano; bez čísla v betě	ano (jména od 2026)	ne	ano	Apple ID
Metadata	server zná členství, jména, účty, časy, IP; ukládá slepá ID, polohy, čísla telefonie; peeri vidí IP	sealed sender, SGX kontakty; vydává jen datum registrace a připojení	IP, zařízení, kontakty, sdílení v Meta	minimum (datum ID, poslední přihlášení)	server drží obsah i kontakty; IP a číslo soudům od 2024	Apple vidí vyhledání klíčů; zálohy bez ADP
Hosting	jen vlastní server (instalátor, Docker)	centrální (kód serveru veřejný)	centrální; EU interoperabilita	centrální; OnPrem	centrální	centrální
Kód / buildy	open source; web doručuje server; build není reprodukovatelný	open; reprodukovatelný Android	uzavřený	aplikace AGPL; repro. build Android experimentálně	klienti open, ověřitelné buildy; server uzavřený	uzavřený
Audity / formální	žádné (revize s pomocí AI)	formální analýzy PQXDH, SPQR (ProVerif, hax/F*)	NCC; audit KT; CCS 2026 našel odchylky od libsinal	Cure53, důkaz lbex (2023)	analýzy MTPProto (Eurocrypt 2025)	Tamarin pro PQ3; ověřená corecrypto
Incidenty 2025–26	neznámé (nenasazené ve velkém)	phishing propojených zařízení (2025)	zero-click CVE-2025-55177; výčet 3,5 mld. účtů	DDoS výpadek 08/2026	hromadné předávání dat	zero-click (Graphite, 2025)

Další aplikace. Wire: MLS (FS + PCS) od 04/2025, self-hosting a federace, bez PQ (jen otevřený PR), bez KT. **Element / Matrix:** federace a self-hosting, Olm FS + PCS, Megolm jen FS, stav místností (část metadat) čitelný serverem, PQ jen plánováno. **Session:** onion routing a bez čísla, ale protokol v1 bez FS i PCS, V2 s ML-KEM nevydána, nadace v roce 2026 bez financí. **SimpleX:** bez identifikátorů uživatele, jednosměrné fronty, Double Ratchet s hybridním PQ (sntrup761) v přímých chatech (ne ve skupinách), self-hosting relé, audits Trail of Bits 2022 a 2024.

Rozbor. V protokolu pro zprávy je M5cet 6.12 srovnatelný se Signalem a iMessage PQ3 (FS, PCS, PQ v ustavení i ratchetu) a **před** WhatsAppem (bez PQ), Threemou (bez PQ, bez PCS), Wire (bez PQ), Telegramem (výchozí chaty bez E2EE) a Session (bez FS). Silnou stránkou je **nezávislost na telefonním čísle a vlastní hosting** — žádný centrální provozovatel, jurisdikce ani sběr dat výrobcem. Zaostává v tom, co rozhoduje v praxi: **ověřitelnost** (žádný audit ani formální důkaz, Signal a iMessage mají formální analýzy, Threema audits), **doručení kódu** (web od serveru vs. podepsané aplikace z obchodu), **metadata** (server ví a ukládá víc než Signal i Threema; Telegram a WhatsApp jsou na tom ještě hůř), **hovory** (Signal, WhatsApp, iMessage, Threema mají E2EE hovorů na všech platformách) a **zralost** (protokol 4 neběžel v provozu ani mezi webem a Androidem). Celá důvěra se přesouvá na provozovatele instance: pro firmu, která server provozuje sama a nedůvěřuje cloudovým službám, je to výhoda; proti zlému nebo kompromitovanému provozovateli chrání M5cet méně než Signal.

4. Srovnání funkcí

	M5cet 6.12	Signal	WhatsApp	Threema	Telegram	iMessage
Platformy	web (PWA), Android; iOS jen web; desktop ne	iOS, Android, desktop	vše vč. webu	vše vč. webu	vše vč. webu	jen Apple
Model chatu	místnosti s heslem, víc místností naráz; soukromé zprávy vybraným členům (bez samostatných 1:1)	1:1, skupiny	1:1, skupiny, komunity	1:1, skupiny	1:1, skupiny, kanály	1:1, skupiny
Velikost skupin / hovorů	bez limitu (provozovatel do 10 000); hovory P2P mesh bez SFU (prakticky 4–5)	1 000? / 75?	1 024 / 32	256 / 16 (32)	200 000 / 200	? / 33
Soubory	P2P bez limitu (Android 2 GiB), přes server do 10 GiB	100 MB?	2 GB	100 MB	2 GB (4 GB)	—
Zprávy	mizející (4 s–2 h, TTL), „podržet a číst“, zabezpečené kódem, odpověď, přeposlání, poloha, potvrzení; chybí úpravy, reakce, ankety, smazání u ostatních	vše standardní	vše standardní	bez časovače mizení	vše standardní	vše standardní
Účty, zařízení	passkey účet, generované jméno, bez čísla; až 10 zařízení přes přihlášení	číslo; propojená zařízení	číslo; 4 propojená zařízení	náhodné ID	číslo, passkeys	Apple ID
Zálohy	trezor historie pod passkey (500 zpráv), zálohy serveru; export chatu ne	zabezpečené zálohy	E2EE záloha volitelně	Threema Safe	cloud	iCloud (ADP)
Boti, AI, integrace	funkce v JS / Pythonu (sandbox), webhooky, plánování; AI asistenti (Claude, OpenAI, lokální modely); řeč TTS / STT	ne	Meta AI, Business API	Work API	boti, mini aplikace, AI	Apple Intelligence
Telefonie, NFC	PSTN / SIP most, SMS, WhatsApp / Viber přes poskytovatele, vizuální call flow (TSA); NFC čtení EMV a e-ID	ne	ne	ne	ne	ne
Správa	vlastní server, konzole (role, audit, metriky), MDM-like design Androidu, instalátor + check.sh	—	—	Threema Work / OnPrem	—	—

5. Hodnocení po oblastech

Oblast (10 = Signal)	6.12	Proč
Zprávy (protokol)	7,5	hybridní PQ + ratchet; nová, neauditovaná implementace
Nepřítomní, soubory	6	schránky pro zařízení; záloha klíčem místnosti
Hovory	4	E2EE rámců jen web; DTLS kotvené heslem
Klíče, kořen důvěry	5	sdílené heslo, náhodný klíč jen volitelný
Identita, ověřování	6	stavy, KT, gossip; log vede provozovatel
Metadata	3	server zná a ukládá hodně, IP mezi peery
Webový klient	5	F-02, kontrola vydání ve výchozím stavu neběží
Android	6,5	silný zámek a trezor; bez E2EE hovorů a pinningu
Server a provoz	6	část úložišť šifrovaná; sandbox bez bwrap ve výchozím stavu
Ověřitelnost	2	bez auditu, formálního modelu, repro buildu
Celkově	≈ 5,5	Signal 10, Threema ≈ 8, WhatsApp ≈ 7, Telegram (výchozí chaty) ≈ 3*

* orientační odhad pro kontext, ne výsledek revize kódu těchto aplikací.

6. Doporučení (pořadí)

- **Hovory:** E2EE rámců i na Androidu (WebRTC FrameEncryptor), otisky DTLS svázat s přepisem protokolu 4; bez E2EE rámců hovor označit.
- **Doručení webu:** podepisovat vydání mimo server a `m5_release_key` v buildu; dlouhodobě reprodukovatelný build, rozšíření prohlížeče nebo desktopová aplikace.
- **Kořen důvěry:** náhodný klíč místnosti vynutit pro nové místnosti (web i Android), `HUB_REQUIRE_ROOM_PROOF=1` jako výchozí po přechodu klientů.
- **Metadata:** šifrovat `m5cet.db`, `android.db`, `ai/journal.db` a JSON úložiště, klíčovat slepá ID ve frontě relay, odstranit hash místnosti z hlaviček push, nepsat těla SMS, master klíč mimo datový adresář (KMS / TPM).
- **Provoz:** instalátor a Docker s bubblewrap + seccomp; 2FA a expirace tokenů konzole; spouštět `check.sh`.
- **Ověřitelnost:** nezávislý audit a formální model (ProVerif / Tamarin) hello v4 a ratchetu, vektory FIPS 203, Android testy v CI, svědci logu klíčů; test web ↔ Android na zařízeních.

7. Co nebylo ověřeno

Provoz na zařízeních a živě mezi webem a Androidem; skutečný Linux s bubblewrap pod systémem; aktuální údaje konkurence mimo uvedené veřejné zdroje (vč. velikostí skupin a limitů souborů u Signalu a iMessage, „?“ = neověřeno). Analýza je revize kódu s pomocí AI (Claude) a **nenahrazuje nezávislý audit**.